Security & AI Control Catalog

Sentinel Nexus — generated from controls_manifest.yaml

Information Security & AI Governance

June 2026

Contents

Summary

Generated from the master controls manifest: **35 controls**, each mapped to its implementing module, proving tests, and its references across OWASP Top 10 for LLM, MITRE ATLAS, NIST AI 600-1, NIST SP 800-53 Rev. 5, and NIST CSF 2.0.

Status	Count
implemented	33
documented	2

Category	Count
AI Security	14
Infrastructure Hardening	1
Ingestion Integrity	3
NIST AI 600-1	13
SIEM Federation	4

Control Catalog

ID	Title	Status	OWASP	ATLAS	NIST AI 600-1	SP 800-53	CSF	Tests
AI-GROUNDING	Confabulated-evidence grounding	implemented	—	—	MS-2.5-003	SI-7	DE	1
AI-MEMORY-TTL	Immunity-memory TTL / expiry	implemented	—	—	GV-1.3-005	SC-28, AU-9	GV, PR	1
AI-PROVENANCE	AI-origin provenance disclosure	implemented	—	—	MP-5.1-003	AU-3	GV	1
AI-REVIEW-BOARD	Adversarial review board (per-expert counterparts)	implemented	LLM09	—	MG-1.3-002	SI-7, RA-3	DE, RS	2
IAC-HARDENING	OS / kernel / network hardening baseline	implemented	—	—	—	AC-17, AU-2, AU-12, CM-7, IA-5, SC-5, SC-7, SI-3, SI-7, SI-16	PR, DE	1
ING-DLQ-BREAKER	Durable worker circuit breaker + dead-letter routing	implemented	—	—	—	SI-4, CP-10	DE, RC	1
ING-ZERO-TRUST	Zero-Trust ingestion gateway (HMAC + 3-tier replay defense)	implemented	—	—	—	SC-7, SC-8, SC-16, SI-7, SI-10, AC-7	PR, DE	1
NC-1-BIAS-AUDIT	Bias/disparity + homogenization scheduled audit	implemented	—	—	MS-2.11-002, GV-1.3-005, MS-2.11-005	AU-6, RA-3	GV, DE	1
NC-10-VERDICT-LINEAGE	Tamper-evident verdict lineage	implemented	—	—	MS-2.8-003	AU-9, AU-10, SI-7	PR, DE	2
NC-11-ENERGY-ACCOUNTING	Per-run inference energy accounting	implemented	—	—	MS-2.12-003	—	GV	2
NC-2-CALIBRATION	Confidence-calibration ledger	implemented	—	—	MS-2.13-001	AU-6, CA-7	GV, DE	1
NC-3-FRONTIER-PIN	Frontier model boot-time version-pin enforcement	implemented	—	—	MP-4.1-007	SR-3, CM-2	GV, ID	1
NC-4-RETENTION	Data retention & decommissioning policy	documented	—	—	GV-1.7-002, MS-2.10-001	SC-28, AU-9, SI-12	GV, PR	0
NC-6-ENERGY	Environmental impact estimate	documented	—	—	MS-2.12-003	—	GV	0

ID	Title	Status	OWASP	ATLAS	NIST AI 600-1	SP 800-53	CSF	Tests
NC-8-OVER-RELIANCE	Automation-bias / over-reliance measurement	implemented	—	—	MG-1.3-002, MP-3.4-005	AU-6, CA-7	GV, DE	2
NC-9-ACTIVE-LEARNING	Active-learning failure capture	implemented	—	—	MG-4.1-004	CA-7, SI-4	ID, DE	2
SEC-BLAST-RADIUS	Blast-radius cap & entity state machine	implemented	LLM08	—	—	AC-6, SI-7	PR, RS	1
SEC-CANARY	Canary token prompt-leak tripwire	implemented	LLM01	AML.T0042	—	SI-4, SI-7	DE, PR	1
SEC-DLP-EGRESS	Outbound DLP / sovereign data isolation	implemented	LLM06	—	—	AC-4, SC-7	PR	1
SEC-DUCKDB-SANDBOX	Read-only data-lake query sandbox	implemented	LLM02, LLM08	—	—	AC-3, AC-6, CM-7, SI-10	PR	1
SEC-ENDPOINT-ID	Endpoint identity injection defense	implemented	—	—	—	SI-10	PR	1
SEC-FAILOVER	Cascading LLM failover & sovereign degradation	implemented	LLM05	—	—	CP-10, SI-4	RC, DE	1
SEC-IDEMPOTENT-SOAR	Idempotent SOAR execution & deduplication	implemented	—	—	—	SI-10, SC-5	RS	1
SEC-MODEL-DOS	Model denial-of-service bounding	implemented	LLM04	—	—	SC-5, SC-6	PR, DE	1
SEC-OUTPUT-SCHEMA	Strict SOAR output-contract enforcement	implemented	LLM07, LLM08	—	—	SI-7, SI-10	PR, RS	1
SEC-REGRESSION-GATE	Deterministic regression / deploy gate	implemented	LLM09	AML.T0043, AML.T0015	—	CM-3, CA-2, SI-7	GV, PR	1
SEC-RLHF-QUARANTINE	Sybil RLHF poisoning quarantine	implemented	LLM03	AML.T0031, AML.T0020	—	SI-4, SI-10, SI-7	PR, DE	1
SEC-SANITIZER	Cognitive boundary isolation & untrusted-payload wrapping	implemented	LLM01	AML.T0043	—	SI-10	PR	1
SEC-SUPPLY-CHAIN	Cryptographic model supply-chain integrity (SHA-384)	implemented	—	AML.T0044	—	SR-3, SR-4, SR-11, SI-7	PR, ID	1

ID	Title	Status	OWASP	ATLAS	NIST AI 600-1	SP 800-53	CSF	Tests
SEC-TRAINING-HYGIENE	Training-data hygiene & credential scrubbing	implemented	LLM03	AML.T0020	—	SI-12, AC-4	PR	1
SEC-VECTOR-DIM	Vector dimensionality validation	implemented	LLM03	—	—	SI-10	PR	1
SIEM-CONFIG-CONTRACT	SIEM config ↔ fanout index contract	implemented	—	—	—	CM-2, AC-4	GV, ID	1
SIEM-COUNTERPART-DISPROOF	Review-board counterpart SIEM disproof	implemented	—	—	MS-2.5-003, MG-1.3-002	—	DE	1
SIEM-E2E	SIEM federation end-to-end conservation	implemented	—	—	—	CA-2, SI-4	DE	1
SIEM-TOOL-GUARD	SIEM query tool — read-only / bounded / allowlist	implemented	LLM02, LLM08	—	—	AC-3, AC-4, SI-10	DE, PR	1

Framework Cross-Correlation

Five lenses on one register — locating a control via any framework surfaces its coverage under the others.

OWASP Top 10 for LLM

Risk	Controls
LLM01	SEC-CANARY, SEC-SANITIZER
LLM02	SEC-DUCKDB-SANDBOX, SIEM-TOOL-GUARD
LLM03	SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE, SEC-VECTOR-DIM
LLM04	SEC-MODEL-DOS
LLM05	SEC-FAILOVER
LLM06	SEC-DLP-EGRESS
LLM07	SEC-OUTPUT-SCHEMA
LLM08	SEC-BLAST-RADIUS, SEC-DUCKDB-SANDBOX, SEC-OUTPUT-SCHEMA, SIEM-TOOL-GUARD
LLM09	AI-REVIEW-BOARD, SEC-REGRESSION-GATE

MITRE ATLAS

Technique	Controls
AML.T0015	SEC-REGRESSION-GATE
AML.T0020	SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE
AML.T0031	SEC-RLHF-QUARANTINE
AML.T0042	SEC-CANARY
AML.T0043	SEC-REGRESSION-GATE, SEC-SANITIZER
AML.T0044	SEC-SUPPLY-CHAIN

NIST AI 600-1 (GenAI Profile)

Action	Controls
GV-1.3-005	AI-MEMORY-TTL, NC-1-BIAS-AUDIT
GV-1.7-002	NC-4-RETENTION
MG-1.3-002	AI-REVIEW-BOARD, NC-8-OVER-RELIANCE, SIEM-COUNTERPART-DISPROOF
MG-4.1-004	NC-9-ACTIVE-LEARNING
MP-3.4-005	NC-8-OVER-RELIANCE

Action	Controls
MP-4.1-007	NC-3-FRONTIER-PIN
MP-5.1-003	AI-PROVENANCE
MS-2.10-001	NC-4-RETENTION
MS-2.11-002	NC-1-BIAS-AUDIT
MS-2.11-005	NC-1-BIAS-AUDIT
MS-2.12-003	NC-11-ENERGY-ACCOUNTING, NC-6-ENERGY
MS-2.13-001	NC-2-CALIBRATION
MS-2.5-003	AI-GROUNDING, SIEM-COUNTERPART-DISPROOF
MS-2.8-003	NC-10-VERDICT-LINEAGE

NIST CSF 2.0 Function

Function	Controls
GV Govern	AI-MEMORY-TTL, AI-PROVENANCE, NC-1-BIAS-AUDIT, NC-11-ENERGY-ACCOUNTING, NC-2-CALIBRATION, NC-3-FRONTIER-PIN, NC-4-RETENTION, NC-6-ENERGY, NC-8-OVER-RELIANCE, SEC-REGRESSION-GATE, SIEM-CONFIG-CONTRACT
ID Identify	NC-3-FRONTIER-PIN, NC-9-ACTIVE-LEARNING, SEC-SUPPLY-CHAIN, SIEM-CONFIG-CONTRACT
PR Protect	AI-MEMORY-TTL, IAC-HARDENING, ING-ZERO-TRUST, NC-10-VERDICT-LINEAGE, NC-4-RETENTION, SEC-BLAST-RADIUS, SEC-CANARY, SEC-DLP-EGRESS, SEC-DUCKDB-SANDBOX, SEC-ENDPOINT-ID, SEC-MODEL-DOS, SEC-OUTPUT-SCHEMA, SEC-REGRESSION-GATE, SEC-RLHF-QUARANTINE, SEC-SANITIZER, SEC-SUPPLY-CHAIN, SEC-TRAINING-HYGIENE, SEC-VECTOR-DIM, SIEM-TOOL-GUARD
DE Detect	AI-GROUNDING, AI-REVIEW-BOARD, IAC-HARDENING, ING-DLQ-BREAKER, ING-ZERO-TRUST, NC-1-BIAS-AUDIT, NC-10-VERDICT-LINEAGE, NC-2-CALIBRATION, NC-8-OVER-RELIANCE, NC-9-ACTIVE-LEARNING, SEC-CANARY, SEC-FAILOVER, SEC-MODEL-DOS, SEC-RLHF-QUARANTINE, SIEM-COUNTERPART-DISPROOF, SIEM-E2E, SIEM-TOOL-GUARD
RS Respond	AI-REVIEW-BOARD, SEC-BLAST-RADIUS, SEC-IDEMPOTENT-SOAR, SEC-OUTPUT-SCHEMA
RC Recover	ING-DLQ-BREAKER, SEC-FAILOVER

NIST CSF 2.0 Category

Category · title	Controls
GV.OV · Oversight	NC-1-BIAS-AUDIT, NC-11-ENERGY-ACCOUNTING, NC-2-CALIBRATION, NC-6-ENERGY, NC-8-OVER-RELIANCE
GV.PO · Policy	NC-4-RETENTION
GV.RR · Roles, Responsibilities & Authorities	AI-PROVENANCE
GV.SC · Cybersecurity Supply Chain Risk Mgmt	NC-3-FRONTIER-PIN, SEC-SUPPLY-CHAIN
ID.AM · Asset Management	NC-3-FRONTIER-PIN, SIEM-CONFIG-CONTRACT
ID.IM · Improvement	NC-2-CALIBRATION, NC-9-ACTIVE-LEARNING, SEC-REGRESSION-GATE
PR.AA · Identity Mgmt, Authn & Access Control	IAC-HARDENING, ING-ZERO-TRUST, SEC-DUCKDB-SANDBOX, SEC-ENDPOINT-ID, SIEM-TOOL-GUARD
PR.DS · Data Security	AI-MEMORY-TTL, ING-ZERO-TRUST, NC-10-VERDICT-LINEAGE, NC-4-RETENTION, SEC-CANARY, SEC-DLP-EGRESS, SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE, SEC-VECTOR-DIM
PR.IR · Technology Infrastructure Resilience	SEC-BLAST-RADIUS, SEC-FAILOVER, SEC-MODEL-DOS
PR.PS · Platform Security	IAC-HARDENING, SEC-DUCKDB-SANDBOX, SEC-OUTPUT-SCHEMA, SEC-REGRESSION-GATE, SEC-SANITIZER, SEC-SUPPLY-CHAIN
DE.AE · Adverse Event Analysis	AI-GROUNDING, AI-REVIEW-BOARD, NC-10-VERDICT-LINEAGE, NC-9-ACTIVE-LEARNING, SIEM-COUNTERPART-DISPROOF
DE.CM · Continuous Monitoring	IAC-HARDENING, ING-DLQ-BREAKER, ING-ZERO-TRUST, NC-1-BIAS-AUDIT, NC-8-OVER-RELIANCE, SEC-CANARY, SEC-MODEL-DOS, SEC-RLHF-QUARANTINE, SIEM-E2E, SIEM-TOOL-GUARD
RS.AN · Incident Analysis	AI-REVIEW-BOARD
RS.MI · Incident Mitigation	SEC-BLAST-RADIUS, SEC-IDEMPOTENT-SOAR, SEC-OUTPUT-SCHEMA
RC.RP · Incident Recovery Plan Execution	ING-DLQ-BREAKER, SEC-FAILOVER

NIST SP 800-53 Rev. 5

Control · OSCAL title	Controls
AC-17 · Remote Access	IAC-HARDENING
AC-3 · Access Enforcement	SEC-DUCKDB-SANDBOX, SIEM-TOOL-GUARD
AC-4 · Information Flow Enforcement	SEC-DLP-EGRESS, SEC-TRAINING-HYGIENE, SIEM-CONFIG-CONTRACT, SIEM-TOOL-GUARD
AC-6 · Least Privilege	SEC-BLAST-RADIUS, SEC-DUCKDB-SANDBOX
AC-7 · Unsuccessful Logon Attempts	ING-ZERO-TRUST
AU-10 · Non-repudiation	NC-10-VERDICT-LINEAGE

Control · OSCAL title	Controls
AU-12 · Audit Record Generation	IAC-HARDENING
AU-2 · Event Logging	IAC-HARDENING
AU-3 · Content of Audit Records	AI-PROVENANCE
AU-6 · Audit Record Review, Analysis, and Reporting	NC-1-BIAS-AUDIT, NC-2-CALIBRATION, NC-8-OVER-RELIANCE
AU-9 · Protection of Audit Information	AI-MEMORY-TTL, NC-10-VERDICT-LINEAGE, NC-4-RETENTION
CA-2 · Control Assessments	SEC-REGRESSION-GATE, SIEM-E2E
CA-7 · Continuous Monitoring	NC-2-CALIBRATION, NC-8-OVER-RELIANCE, NC-9-ACTIVE-LEARNING
CM-2 · Baseline Configuration	NC-3-FRONTIER-PIN, SIEM-CONFIG-CONTRACT
CM-3 · Configuration Change Control	SEC-REGRESSION-GATE
CM-7 · Least Functionality	IAC-HARDENING, SEC-DUCKDB-SANDBOX
CP-10 · System Recovery and Reconstitution	ING-DLQ-BREAKER, SEC-FAILOVER
IA-5 · Authenticator Management	IAC-HARDENING
RA-3 · Risk Assessment	AI-REVIEW-BOARD, NC-1-BIAS-AUDIT
SC-16 · Transmission of Security and Privacy Attributes	ING-ZERO-TRUST
SC-28 · Protection of Information at Rest	AI-MEMORY-TTL, NC-4-RETENTION
SC-5 · Denial-of-service Protection	IAC-HARDENING, SEC-IDEMPOTENT-SOAR, SEC-MODEL-DOS
SC-6 · Resource Availability	SEC-MODEL-DOS
SC-7 · Boundary Protection	IAC-HARDENING, ING-ZERO-TRUST, SEC-DLP-EGRESS
SC-8 · Transmission Confidentiality and Integrity	ING-ZERO-TRUST
SI-10 · Information Input Validation	ING-ZERO-TRUST, SEC-DUCKDB-SANDBOX, SEC-ENDPOINT-ID, SEC-IDEMPOTENT-SOAR, SEC-OUTPUT-SCHEMA, SEC-RLHF-QUARANTINE, SEC-SANITIZER, SEC-VECTOR-DIM, SIEM-TOOL-GUARD
SI-12 · Information Management and Retention	NC-4-RETENTION, SEC-TRAINING-HYGIENE
SI-16 · Memory Protection	IAC-HARDENING
SI-3 · Malicious Code Protection	IAC-HARDENING
SI-4 · System Monitoring	ING-DLQ-BREAKER, NC-9-ACTIVE-LEARNING, SEC-CANARY, SEC-FAILOVER, SEC-RLHF-QUARANTINE, SIEM-E2E
SI-7 · Software, Firmware, and Information Integrity	AI-GROUNDING, AI-REVIEW-BOARD, IAC-HARDENING, ING-ZERO-TRUST, NC-10-VERDICT-LINEAGE, SEC-BLAST-RADIUS, SEC-CANARY, SEC-OUTPUT-SCHEMA, SEC-REGRESSION-GATE, SEC-RLHF-QUARANTINE, SEC-SUPPLY-CHAIN
SR-11 · Component Authenticity	SEC-SUPPLY-CHAIN
SR-3 · Supply Chain Controls and Processes	NC-3-FRONTIER-PIN, SEC-SUPPLY-CHAIN
SR-4 · Provenance	SEC-SUPPLY-CHAIN

Control Detail

Each implemented control's *proving code* is extracted verbatim (cited by `file:line`) into the **Control Evidence Dossier** (`control_evidence.pdf`) and, per control, under `artifacts/`.

AI Security

SEC-BLAST-RADIUS — Blast-radius cap & entity state machine *(status: implemented; owner: Platform Engineering)*

MAX_ENTITIES cap (in-node), GLOBAL_DO_NOT_PIVOT drop at reduce, severity-monotonic entity status, TIER-1 assets force manual review.

- Implementation: `analytics/llm_hunter/state.py`
- Tests: `tests/lab_analytics_hunter/test_hunter_contracts.py`
- Code evidence: `artifacts/SEC-BLAST-RADIUS.md` (extracted snippets)

SEC-CANARY — Canary token prompt-leak tripwire *(status: implemented; owner: Platform Engineering)*

UUID canary injected into agent prompts; a leak in any output halts the SOAR pipeline.

- Implementation: `analytics/llm_hunter/tools/sanitizer.py`
- Tests: `tests/lab_agentic_swarm/test_agentic_swarm_contracts.py`
- Code evidence: `artifacts/SEC-CANARY.md` (extracted snippets)

SEC-DLP-EGRESS — Outbound DLP / sovereign data isolation *(status: implemented; owner: Platform Engineering)*

CognitiveSanitizer scrubs RFC-1918 ranges + high-entropy credentials from any payload before frontier egress.

- Implementation: `analytics/llm_hunter/tools/sanitizer.py`
- Tests: `tests/lab_redteam/test_cognitive_bypass.py`
- Code evidence: `artifacts/SEC-DLP-EGRESS.md` (extracted snippets)

SEC-DUCKDB-SANDBOX — Read-only data-lake query sandbox *(status: implemented; owner: Platform Engineering)*

Ephemeral in-memory DuckDB, destructive-keyword + local-FS block, auto LIMIT, per-cell truncation + untrusted wrapping.

- Implementation: `analytics/llm_hunter/tools/duckdb_query.py`
- Tests: `tests/lab_analytics_hunter/test_query_cookbook.py`
- Code evidence: `artifacts/SEC-DUCKDB-SANDBOX.md` (extracted snippets)

SEC-FAILOVER — Cascading LLM failover & sovereign degradation *(status: implemented; owner: Platform Engineering)*

Per-node provider failover chain; total failure emits a safe default verdict (monitor) rather than crashing — degrade-to-monitoring.

- Implementation: `analytics/llm_hunter/agents/llm_providers.py`
- Tests: `tests/test_worker_contracts.py`
- Code evidence: `artifacts/SEC-FAILOVER.md` (extracted snippets)

SEC-IDEMPOTENT-SOAR — Idempotent SOAR execution & deduplication *(status: implemented; owner: Platform Engineering)*

15-minute rolling idempotency key (Nats-Msg-Id) + 7-day Redis event dedup so containment applies exactly once.

- Implementation: `analytics/llm_hunter/agents/response.py`
- Tests: `tests/lab_agentic_swarm/test_agentic_swarm_contracts.py`
- Code evidence: `artifacts/SEC-IDEMPOTENT-SOAR.md` (extracted snippets)

SEC-MODEL-DOS — Model denial-of-service bounding *(status: implemented; owner: Platform Engineering)*

LangGraph recursion_limit + absolute asyncio timeouts bound execution; neutralizes context-saturation/VRAM-exhaustion attacks.

- Implementation: `analytics/llm_hunter/orchestrator.py`
- Tests: `tests/lab_agentic_swarm/test_agentic_swarm_contracts.py`
- Code evidence: `artifacts/SEC-MODEL-DOS.md` (extracted snippets)

SEC-OUTPUT-SCHEMA — Strict SOAR output-contract enforcement *(status: implemented; owner: Platform Engineering)*

All execution plans validated against SoarExecutionSchema (blast-radius cap, enum actions); off-contract payloads dropped.

- Implementation: `analytics/llm_hunter/state.py`
- Tests: `tests/lab_agentic_swarm/test_agentic_swarm_contracts.py`
- Code evidence: `artifacts/SEC-OUTPUT-SCHEMA.md` (extracted snippets)

SEC-REGRESSION-GATE — Deterministic regression / deploy gate *(status: implemented; owner: MLOps)*

03_eval_model.py gauntlet (OS-context, schema, injection, spatial, SIEM-pivot validity); <99% accuracy halts deploy.

- Implementation: `mlops/scripts/03_eval_model.py`
- Tests: `tests/lab_mlops_serving/test_mlops_serving.py`
- Code evidence: `artifacts/SEC-REGRESSION-GATE.md` (extracted snippets)

SEC-RLHF-QUARANTINE — Sybil RLHF poisoning quarantine *(status: implemented; owner: MLOps)*

worker_rlhf monitors operator-override velocity; coordinated malicious dismissals trip an atomic circuit breaker quarantining the tainted reward data.

- Implementation: `services/worker_rlhf/src/main.rs`
- Tests: `tests/test_worker_contracts.py`
- Code evidence: `artifacts/SEC-RLHF-QUARANTINE.md` (extracted snippets)

SEC-SANITIZER — Cognitive boundary isolation & untrusted-payload wrapping *(status: implemented; owner: Platform Engineering)*

Adversary-controlled telemetry wrapped in dynamic XML boundaries, control tokens defanged, HTML-escaped; experts forbidden to obey untrusted content.

- Implementation: `analytics/llm_hunter/tools/sanitizer.py`
- Tests: `tests/lab_redteam/test_cognitive_bypass.py`
- Code evidence: `artifacts/SEC-SANITIZER.md` (extracted snippets)

SEC-SUPPLY-CHAIN — Cryptographic model supply-chain integrity (SHA-384) *(status: implemented; owner: MLOps)*

Boot verifies SHA-384 of model weights against build-time digests; mismatch refuses to load.

- Implementation: `mlops/serve_vllm.sh`
- Tests: `tests/lab_mlops_serving/test_mlops_serving.py`
- Code evidence: `artifacts/SEC-SUPPLY-CHAIN.md` (extracted snippets)

SEC-TRAINING-HYGIENE — Training-data hygiene & credential scrubbing *(status: implemented; owner: MLOps)*

Regex credential sanitization on every telemetry payload before it enters the corpus; deterministic 85/15 held-out split.

- Implementation: `mlops/scripts/01_spool_datasets.py`
- Tests: `tests/lab_mlops_serving/test_mlops_serving.py`
- Code evidence: `artifacts/SEC-TRAINING-HYGIENE.md` (extracted snippets)

SEC-VECTOR-DIM — Vector dimensionality validation *(status: implemented; owner: Platform Engineering)*

QdrantVectorSearchTool validates target vector dimensionality per named space before search; rejects malformed/adversarial vectors.

- Implementation: `analytics/llm_hunter/tools/qdrant_search.py`
- Tests: `tests/lab_analytics_hunter/test_hunter_contracts.py`
- Code evidence: `artifacts/SEC-VECTOR-DIM.md` (extracted snippets)

Infrastructure Hardening

IAC-HARDENING — OS / kernel / network hardening baseline *(status: implemented; owner: Infrastructure)*

sysctl (ASLR, rp_filter, syncookies, no source-routing), mount hardening (noexec/nosuid/nodev), SSH lockdown, default-DROP firewall, auditd + AIDE + fail2ban, account policy, rootless Podman.

- Implementation: `hardening/tasks/main.yml`
- Tests: `infrastructure/tests/test_infrastructure.py`
- Code evidence: `artifacts/IAC-HARDENING.md` (extracted snippets)

Ingestion Integrity

ING-DLQ-BREAKER — Durable worker circuit breaker + dead-letter routing *(status: implemented; owner: Platform Engineering)*

Exponential-backoff retry, circuit breaker, poison-message DLQ with metrics; graceful SIGTERM drain.

- Implementation: `libs/lib_siem_core/src/lib.rs`
- Tests: `tests/test_worker_contracts.py`
- Code evidence: `artifacts/ING-DLQ-BREAKER.md` (extracted snippets)

ING-ZERO-TRUST — Zero-Trust ingestion gateway (HMAC + 3-tier replay defense) *(status: implemented; owner: Platform Engineering)*

TLS+JWT; HMAC-SHA256 canonical lineage stamp; temporal-drift, monotonic-sequence, cross-OS/collision validation; adaptive sensor banning.

- Implementation: `services/core_ingress/src/integrity.rs`
- Tests: `tests/test_worker_contracts.py`

- Code evidence: `artifacts/ING-ZERO-TRUST.md` (extracted snippets)

SEC-ENDPOINT-ID — Endpoint identity injection defense *(status: implemented; owner: Platform Engineering)*

Sensor endpoint_id regex-validated in the Rust ingestion layer before reaching Qdrant/Parquet (blocks injection/path traversal).

- Implementation: `libs/lib_siem_core/src/models.rs`
- Tests: `tests/test_worker_contracts.py`
- Code evidence: `artifacts/SEC-ENDPOINT-ID.md` (extracted snippets)

NIST AI 600-1

AI-GROUNDING — Confabulated-evidence grounding *(status: implemented; owner: AI Governance)*

A confirmed TP citing an artifact never retrieved is demoted to monitor (fail-closed).

- Implementation: `analytics/llm_hunter/agents/controls.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestGroundingEnforcement`
- Code evidence: `artifacts/AI-GROUNDING.md` (extracted snippets)

AI-MEMORY-TTL — Immunity-memory TTL / expiry *(status: implemented; owner: AI Governance)*

Stored FP signatures expire (default 30 d) so a stale/wrong FP cannot entrench a permanent blind spot.

- Implementation: `analytics/llm_hunter/agents/controls.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestMemoryTTL`
- Code evidence: `artifacts/AI-MEMORY-TTL.md` (extracted snippets)

AI-PROVENANCE — AI-origin provenance disclosure *(status: implemented; owner: AI Governance)*

Every incident report is stamped AI-generated so consumers are never misled.

- Implementation: `analytics/llm_hunter/agents/controls.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestProvenanceDisclosure`
- Code evidence: `artifacts/AI-PROVENANCE.md` (extracted snippets)

AI-REVIEW-BOARD — Adversarial review board (per-expert counterparts) *(status: implemented; owner: AI Governance)*

Each expert has a counterpart that tries to disprove the finding; TP only if none can. Fails closed.

- Implementation: `analytics/llm_hunter/agents/review_board.py`
- Tests: `tests/lab_analytics_hunter/test_review_board.py`, `tests/lab_analytics_hunter/test_review_board_simulation.py`
- Code evidence: `artifacts/AI-REVIEW-BOARD.md` (extracted snippets)

NC-1-BIAS-AUDIT — Bias/disparity + homogenization scheduled audit *(status: implemented; owner: AI Governance)*

Job scrolls verdict/immunity memory; disaggregated containment-disparity + model-collapse monitor; writes a flagged report.

- Implementation: `analytics/llm_hunter/agents/bias_audit.py`
- Tests: `tests/lab_analytics_hunter/test_nist_controls_wave2.py::TestBiasAudit`
- Code evidence: `artifacts/NC-1-BIAS-AUDIT.md` (extracted snippets)

NC-10-VERDICT-LINEAGE — Tamper-evident verdict lineage *(status: implemented; owner: AI Governance)*

Append-only SHA-256 hash chain over verdict/audit records; any post-hoc edit, deletion, or reorder breaks verification — a tamper-evident trail for autonomous decisions.

- Implementation: `analytics/llm_hunter/agents/verdict_ledger.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestVerdictLineage`, `tests/lab_analytics_hunter/test_nist_controls_wave4.py`
- Code evidence: `artifacts/NC-10-VERDICT-LINEAGE.md` (extracted snippets)

NC-11-ENERGY-ACCOUNTING — Per-run inference energy accounting *(status: implemented; owner: AI Governance)*

Folds the one-time footprint estimate (NC-6) into a per-run energy (Wh) + carbon (gCO2e) measurement the MLOps metric plane rolls up.

- Implementation: `analytics/llm_hunter/agents/energy_accounting.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestInferenceEnergy`, `tests/lab_analytics_hunter/test_nist_controls_wave4.`
- Code evidence: `artifacts/NC-11-ENERGY-ACCOUNTING.md` (extracted snippets)

NC-2-CALIBRATION — Confidence-calibration ledger *(status: implemented; owner: AI Governance)*

Pairs operator dispositions with predicted confidence into a Brier/over-confidence trend.

- Implementation: `analytics/llm_hunter/agents/calibration_ledger.py`
- Tests: `tests/lab_analytics_hunter/test_nist_controls_wave2.py::TestCalibrationLedger`
- Code evidence: `artifacts/NC-2-CALIBRATION.md` (extracted snippets)

NC-3-FRONTIER-PIN — Frontier model boot-time version-pin enforcement *(status: implemented; owner: AI Governance)*

build_failover_chain refuses a frontier provider on a floating alias unless explicitly opted in.

- Implementation: `analytics/llm_hunter/agents/llm_providers.py`
- Tests: `tests/lab_analytics_hunter/test_nist_controls_wave2.py::TestFrontierPinEnforcement`
- Code evidence: `artifacts/NC-3-FRONTIER-PIN.md` (extracted snippets)

NC-4-RETENTION — Data retention & decommissioning policy *(status: documented; owner: AI Governance)*

Retention/expiry + secure decommission + membership-inference posture for AI data stores.

- Implementation: `docs/governance/data_retention_decommission_policy.md`
- Tests: *(documentation control)*

NC-6-ENERGY — Environmental impact estimate *(status: documented; owner: AI Governance)*

Training/inference footprint estimate + tracking approach.

- Implementation: `docs/governance/environmental_impact_estimate.md`
- Tests: *(documentation control)*

NC-8-OVER-RELIANCE — Automation-bias / over-reliance measurement *(status: implemented; owner: AI Governance)*

Measures the human side of HitL — accept-vs-override and how often a wrong AI call is rubber-stamped (automation bias), by AI-confidence band, over operator dispositions.

- Implementation: `analytics/llm_hunter/agents/calibration_ledger.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestOverReliance`, `tests/lab_analytics_hunter/test_nist_controls_wave4.py:`
- Code evidence: `artifacts/NC-8-OVER-RELIANCE.md` (extracted snippets)

NC-9-ACTIVE-LEARNING — Active-learning failure capture *(status: implemented; owner: AI Governance)*

Captures the swarm's misclassifications + ungrounded-evidence verdicts as a structured hard-example corpus for MLOps continuous improvement.

- Implementation: `analytics/llm_hunter/agents/active_learning.py`
- Tests: `tests/lab_analytics_hunter/test_ai_controls.py::TestActiveLearningFailure`, `tests/lab_analytics_hunter/test_nist_controls_`
- Code evidence: `artifacts/NC-9-ACTIVE-LEARNING.md` (extracted snippets)

SIEM Federation

SIEM-CONFIG-CONTRACT — SIEM config ↔ fanout index contract *(status: implemented; owner: Platform Engineering)*

Sovereign-by-default [siem] config; the swarm's queryable indexes are contract-tested against the middleware fanout.

- Implementation: `analytics/llm_hunter/tools/nexus_config.py`
- Tests: `tests/lab_analytics_hunter/test_siem_config.py`
- Code evidence: `artifacts/SIEM-CONFIG-CONTRACT.md` (extracted snippets)

SIEM-COUNTERPART-DISPROOF — Review-board counterpart SIEM disproof *(status: implemented; owner: AI Governance)*

Counterparts run a cross-source prevalence query to disprove a finding; fails to transcript-only when no SIEM.

- Implementation: `analytics/llm_hunter/agents/review_board.py`
- Tests: `tests/lab_analytics_hunter/test_siem_review_board.py`
- Code evidence: `artifacts/SIEM-COUNTERPART-DISPROOF.md` (extracted snippets)

SIEM-E2E — SIEM federation end-to-end conservation *(status: implemented; owner: Platform Engineering)*

Fanout (real CIM/ECS mappings) → mock SIEM → swarm pivot; write↔read conservation + disproof proven.

- Implementation: `tests/lab_siem_federation/test_siem_federation_e2e.py`
- Tests: `tests/lab_siem_federation/test_siem_federation_e2e.py`
- Code evidence: `artifacts/SIEM-E2E.md` (extracted snippets)

SIEM-TOOL-GUARD — SIEM query tool — read-only / bounded / allowlist *(status: implemented; owner: Platform Engineering)*

Splunk SPL / Elastic ES|QL pivot; rejects generating/destructive commands, forces time+row bounds, config-driven index allowlist, untrusted-wraps results, fails open.

- Implementation: `analytics/llm_hunter/tools/siem_query.py`
- Tests: `tests/lab_analytics_hunter/test_siem_query.py`
- Code evidence: `artifacts/SIEM-TOOL-GUARD.md` (extracted snippets)